FC Fluxo de Caixa

DOCUMENTO 06

Segurança

STRIDE, OAuth2, multi-tenant, OWASP API, criptografia, LGPD e rotação de segredos

PROJETO

Fluxo de Caixa — Desafio de Arquiteto de Soluções

AUTOR

Bruno Aquino

DATA

11/11/2026

REPOSITÓRIO

github.com/brunoaquino/fluxo-caixa

Java 25 · Spring Boot 4 · AWS ECS Fargate · Terraform · C4 · DDD · ADRs

Sumário

1. Ameaças (STRIDE) 3

2. Autenticação e autorização 3

3. Critérios para consumir e integrar 4

4. OWASP API Security Top 10 (2023) 5

5. Criptografia 5

6. Segredos e IAM 6

7. Supply chain 8

8. LGPD e auditoria 8

9. O que a segurança não promete 9

FONTE: DOCUMENTOS-BRUTOS/06-SEGURANCA.MD

06 — Segurança

Critério de consumo e de integração, não só de login. O lançamento é fato financeiro: autenticar sem autorizar o tenant, ou integrar a fila sem idempotência e sem política, abre buraco que o TLS não fecha.

1. Ameaças (STRIDE)

Ameaça	Superfície neste sistema	O que reduz
Spoofing	Token forjado; cliente que manda `comerciante_id` no JSON; chamada direta ao execute-api	JWKS no gateway e de novo no serviço, issuer fixo, claim lido só do token, WAF regional exige `X-Origin-Verify`
Tampering	Evento alterado na fila; lançamento alterado no banco; corpo JSON fora do contrato	TLS, SSE-KMS na fila, sem endpoint de update, security group do RDS fechado, request validator no gateway
Repudiation	Comerciante nega um débito	Trilha append-only, `criadoEm`, `eventId`, log com o id do lançamento (sem a descrição)
Information disclosure	Saldo de outro comerciante; descrição em log; backup aberto	404 cruzado, filtro em toda query, log minimizado, RDS criptografado, backup na mesma região
Denial of service	Pico falso, payload grande, poison message, token inválido em massa	WAF rate-based, throttle e usage plan no gateway, `size` máximo 50, período máximo 366 dias, pool JDBC limitado, DLQ
Elevation of privilege	Token de leitura usado para POST; task role que publica e consome	Escopo no authorizer e de novo no serviço, IAM separado por serviço, sem papel admin na API

Não há superfície de upload de arquivo, de webhook de saída definido pelo cliente nem de SQL concatenado. SSRF não tem por onde entrar enquanto a aplicação não buscar URL vinda do request. Se um dia buscar, o item entra nesta tabela antes do código.

2. Autenticação e autorização

- OAuth2/OIDC. Access token JWT. O API Gateway valida assinatura e escopo na borda. Os dois serviços validam de novo (ADR 0011). As duas camadas não são redundância acidental: o gateway não roda no laboratório, e um token que passasse por um bug do authorizer ainda encontra o resource server.
- Escopos: `lancamentos:write`, `lancamentos:read`, `consolidado:read`. Autoridade Spring `SCOPE_` + prefixo. Prefixo vazio no Keycloak, `fluxo-caixa/` no Cognito.
- Multi-tenant: claim `comerciante_id`. Toda query tem esse predicado. 404 para id alheio, para não confirmar existência.
- O consolidado não confia no `comercianteId` do evento sem ser o campo que o produtor colocou. A fila não é pública: só o task role de lançamentos publica, só o de consolidado consome. Um evento com `comercianteId` arbitrário só nasce se o serviço de escrita for comprometido — aí o problema já é outro, e a trilha ainda mostra o `lancamentoId`.

- Client local `fluxo-caixa-app` com direct access grant é de laboratório. Produção não replica senha de usuário no curl do README.

3. Critérios para consumir e integrar

Quem for integrar (PDV, BFF futuro, segundo consumidor da fila) atende a esta lista. Ela é o diferencial de "critério de segurança para consumo de serviços" do desafio.

Critério	Integração HTTP	Integração por evento
Autenticação	Bearer JWT do nosso issuer. API key só para consumidor de integração no usage plan (`api_consumers`). Cliente final não carrega chave: `api_key_required` nasce falso.	IAM da fila. Sem endpoint HTTP de "injeta evento".
Autorização	Escopo no authorizer (`fluxo-caixa/lancamentos:write` , `lancamentos:read` , `consolidado:read`) e de novo no serviço. Leitura não recebe write.	Task role só da fila que lhe cabe. Segundo consumidor ganha fila própria e role própria, não a senha da fila do consolidado.
Tenant	Não enviar `comercianteId` no corpo. O servidor descarta.	O produtor é o único autorizado a preencher `comercianteId` . Consumidor não "corrige" tenant.
Transporte	TLS 1.2+ no CloudFront (ACM em `us-east-1`). Entre task e RDS/Redis, TLS (Redis `REDIS_SSL=true` na AWS).	TLS do endpoint AWS + SSE-KMS.
Rede	A URL pública é o CloudFront. O `execute-api` responde, e o WAF regional só deixa passar `X-Origin-Verify` atual ou anterior. O ALB não tem IP público.	Security group: task não fala com a internet exceto NAT residual; SQS/SNS via endpoint.
Contrato	`/api/v1` , problema RFC 9457, ignorar campo desconhecido.	`eventVersion` . Versão desconhecida vai para DLQ, não é aplicada pela metade.
Idempotência	`Idempotency-Key` no POST de quem cobra ou vende de verdade.	Deduplicar por `eventId` .
Abuso	Throttle do stage e do método, usage plan do consumidor, 401/403 do authorizer, 409 e 429. Não fazer retry cego de 4xx.	Visibility timeout respeitado; não apagar mensagem antes do commit.
Segredo	Token não vai para log, query string nem `Referer` .	Segredo de banco não vai na imagem, no evento nem no Terraform em claro.
mTLS serviço a serviço	Não há chamada entre os dois serviços. Quando houver, o critério passa a ser mTLS ou IAM auth (VPC Lattice / mesh), não uma rede "confiável" aberta.	A fila já é o controle: sem mTLS adicional no SQS, a policy IAM é o mecanismo equivalente.

Assinatura do evento (HMAC do payload) não está ligada. A combinação de raw message delivery com policy da fila e rede fechada é o controle atual. Assinatura do payload entra se um segundo produtor puder publicar no mesmo tópico ou se a fila deixar de ser privada. Até lá, assinatura seria chave para distribuir e girar sem um agressor no caminho. A decisão fica registrada para não parecer esquecimento.

Rate limit: WAF na borda, grosso, por IP, e throttle do API Gateway por método. O GET do consolidado fica acima de 50 req/s em hml e prod. Usage plan dá cota ao consumidor de integração. Limite fino por comerciante, se necessário, é filtro na aplicação com contador no Redis — não está no caminho crítico desta versão

porque o pico legítimo ainda é pequeno e um limite apertado viola o RNF de perda. O WAF não substitui validação de entrada. O request validator do gateway aplica o JSON Schema do POST; o Bean Validation e o domínio repetem a regra.

Validação de entrada: tipo fechado, valor com no máximo duas casas e positivo, descrição 1..255, categoria até 60, data ISO, período ≤ 366 dias, `size` ≤ 50, UUID na chave de idempotência. O model do gateway é a primeira peneira. Bean validation na task, invariante de novo no domínio. O que passa das duas bordas e fura o domínio é bug, não "defesa em profundidade opcional".

4. OWASP API Security Top 10 (2023)

Item	Como aparece aqui	Controle
API1 BOLA	GET de lançamento por id	Id sempre com `comerciante_id` do token. 404 se não casar. Teste com dois usuários.
API2 Broken authentication	JWT	Issuer, audiência, expiração, algoritmo assimétrico, no authorizer e no serviço. Segredo simétrico não é aceito.
API3 Broken object property	Mass assignment de tenant ou de `id`	O model do gateway recusa propriedade desconhecida. O DTO de criação não tem `comercianteId` nem `id`.
API4 Unrestricted resource consumption	Lista e período	`size` ≤ 50, período ≤ 366, timeout de banco, pool limitado, WAF, throttle do gateway e usage plan.
API5 BFLA	Escopo	`consolidado:read` não registra lançamento. O authorizer e o serviço respondem 403.
API6 Sensitive business flows	POST de crédito repetido	Idempotency-Key. Não há fluxo anônimo de criação de conta nesta API.
API7 SSRF	Não há URL no contrato	Não buscar URL do cliente. Se surgir webhook, allowlist e bloqueio de IP interno.
API8 Security misconfiguration	Actuator, CORS, stack trace, bypass do CloudFront	Health não é rota do gateway. CORS fechado até existir front conhecido. Problem Details sem stack. Debug desligado em `aws`. Header `X-Origin-Verify` no WAF regional.
API9 Improper inventory	Serviço esquecido	Dois serviços, um contrato `/api/v1` no gateway, path único no ALB interno, uma distribuição CloudFront. Sem ambiente "demo" com senha na internet.
API10 Unsafe consumption of APIs	Consumo do próprio evento	ACL, versão, DLQ, idempotência. Não se chama API de terceiro com o payload do comerciante nesta versão.

5. Criptografia

Dado	Em trânsito	Em repouso
API pública	TLS no CloudFront (ACM em `us-east-1`), TLS 1.2+. O API Gateway regional também é HTTPS. O trecho VPC Link → ALB interno é HTTP na VPC. O ALB não tem IP público	—

Dado	Em trânsito	Em repouso
JDBC	`sslmode=require` na AWS	RDS criptografado com KMS
Redis	TLS na AWS (`REDIS_SSL=true`); sem TLS no Docker local	ElastiCache at-rest encryption
SNS, SQS, DLQ	HTTPS da API AWS	SSE-KMS
Segredos	SDK sobre TLS	Secrets Manager, KMS
Backup RDS	Canal da AWS	Mesma chave, `us-east-1` . Sem cópia para `sa-east-1`
Imagem ECR	HTTPS	Criptografia do ECR
Access log do ALB	Entrega do ELB na VPC	SSE-S3. O ELB não grava nesse bucket com CMK
Disco local do desenvolvedor	—	Fora do escopo; não se copia base de produção para o notebook

Nove CMKs em cada ambiente (storage e secret de cada RDS, ElastiCache, mensageria, logs, ECR e o header `X-Origin-Verify`), com rotação anual. O access log do ALB é a exceção: SSE-S3, porque o ELB recusa o bucket com CMK.

6. Segredos e IAM

- Senha de banco gerada pelo Secrets Manager, injetada na task, nunca em variável no repositório. O exemplo `lancamentos/lancamentos` do blueprint é só o Compose local.
- Task role de lançamentos: `sns:Publish` no tópico nomeado, `secretsmanager:GetSecretValue` no segredo dela, escrita de log no log group dela. Sem `sqs:ReceiveMessage` .
- Task role do consolidado: `sqs:ReceiveMessage` , `DeleteMessage` , `GetQueueAttributes` na fila e, para o redrive operado por gente e não pela task, a role de operação é outra. `GetSecretValue` só do segredo dela.
- Role de CI: push no ECR e update do service. Sem `rds:DeleteDBInstance` no pipeline de aplicação.
- Role humana de prod: leitura de log e métrica. Apply de Terraform em prod por pipeline, não por access key no laptop.
- Lambda de pre-token: permissão só de execução e log. Sem acesso a RDS.

Least privilege aqui é lista curta de ARN, não `Resource: "*"` .

Rotação

O mecanismo, o runbook e o alarme `RotationFailed` estão no ADR 0024. Resumo operacional:

Segredo ou credencial	Dono	Mecanismo	Frequência
Senha do RDS de lançamentos	RDS + Secrets Manager	`manage_master_user_password`, Advanced JDBC Wrapper rebusca via `DB_SECRET_ARN`	30 dias em prod e hml; 90 em dev
Senha do RDS de consolidado	idem	idem	idem
CMK	KMS	Rotação automática	anual
Certificado do CloudFront	ACM em `us-east-1`	Renovação gerenciada	alarme se faltarem menos de 14 dias
Chave de assinatura JWT	Cognito	JWKS dinâmico, cache curto no serviço	quando o Cognito girar
`X-Origin-Verify`	Secrets Manager + Lambda	Protocolo create/set/test/finish. O Terraform lê `AWSCURRENT` (`current` e `previous`) e reaplica esse par no CloudFront e no WAF. O bootstrap é write-only e não regrava o segredo. O valor anterior continua aceito até a rotação seguinte	30 dias em prod e hml; 90 em dev
Credencial de CI	GitHub OIDC → role IAM	Sem access key de longa duração	a role não tem segredo
AUTH token do Redis	—	Desligado. TLS e security group	—

Hikari `maxLifetime` de 15 minutos, menor que o intervalo de rotação. A role da task tem `GetSecretValue` só no ARN do próprio segredo e `kms:Decrypt` na CMK dele. Local e teste não definem `DB_SECRET_ARN` e usam o driver PostgreSQL comum.

O header `X-Origin-Verify` não volta ao valor de bootstrap no apply seguinte. O resource da versão usa `secret_string_wo`: o sorteio efêmero não fica nesse resource, e `secret_string_wo_version` só reenvia o segredo se for incrementado. CloudFront e a Web ACL leem o estágio `AWSCURRENT`. O que permanece no state é o par lido pelo data source, o custom header da origem e as strings da regra. A distribuição não tem como guardar o header fora do state. Não há `ignore_changes` nesses dois recursos: rota nova e regra nova continuam no plan.

O POST de estorno aceita corpo ausente. O validator desse método não exige JSON. Se o cliente manda `motivo`, o serviço aplica `@Size(max = 255)`. O POST de lançamento continua validando o corpo no gateway.

Runbook curto, quando a rotação automática falhar ou a senha vazar: girar um segredo por vez; o wrapper rebusca na falha de autenticação; se o pool segurar a conexão velha, o `maxLifetime` limita a espera e um deployment novo do ECS corta. Confirmar sessão nova em `pg_stat_activity` e o fim do 5xx. Não desabilitar a CMK do RDS para “forçar” rotação: isso é indisponibilidade.

7. Supply chain

Controle	Onde
Dependabot ou equivalente no GitHub	Maven e Actions, semanal
Build reproduzível	Maven wrapper commitado, versão de plugin pinada
Imagem	Dockerfile com Temurin oficial, usuário não-root, sem segredo em `ENV`
Scan de imagem	ECR scan on push, imagem imutável (tag por digest no deploy, não `latest` em prod)
SBOM	CycloneDX gerado no build Maven (`cyclonedx-maven-plugin`) e anexado ao artefato do CI
SAST	No pipeline, sobre o diff (a ferramenta exata pode ser CodeQL no Actions, que não tem licença extra para repositório público)
DAST	Contra o dev ou o local, com token de teste, fora do pico de produção. ZAP baseline cabe como evolução; o mínimo desta entrega é o teste de autorização automatizado
Ação de CI	SHA pinado nas actions de terceiros, não `@v1` flutuante, quando o workflow for escrito

LocalStack, k6 e Grafana não entram na imagem de produção. A licença AGPL deles não se mistura ao binário do serviço porque eles não são distribuídos dentro dele. Isso está reiterado em custos para não virar "tudo é open source" sem olhar a licença.

8. LGPD e auditoria

Dado pessoal potencial: descrição livre do lançamento, identificador do comerciante, logs de acesso. Não há CPF no contrato. Se o operador escrever CPF na descrição, o campo vira dado pessoal por uso, e a mitigação é orientação de produto mais minimização — o sistema não tem como adivinhar.

Princípio	Tratamento
Finalidade	Operar o caixa do próprio comerciante.
Minimização	Evento sem descrição e sem categoria. Log sem descrição e sem token.
Transferência	`us-east-1` , com cláusulas-padrão e DPA da AWS (ADR 0021). O corpo do POST é inspecionado no WAF; o log do WAF redige corpo e `Authorization` .
Acesso	O comerciante lê os próprios lançamentos pela API. Exportação em massa é evolução.
Eliminação	Lançamento não se apaga. Cadastro no Cognito pode ser removido ao encerrar a conta, preservando a trilha pelo prazo comercial aplicável. Não há `DELETE /lancamentos/{id}` .
Segurança	Seções anteriores.

Auditoria:

- CloudTrail na conta, em todas as regiões usadas, log de gestão imutável (bucket com versionamento e sem delete para o dia a dia).
- A trilha de negócio é a tabela `lancamento`, append-only, com estorno vinculado.
- `eventos_processados` diz qual evento já virou saldo.
- Não se usa a descrição como log de auditoria paralelo.

9. O que a segurança não promete

Não há pentest contratado nesta entrega. Não há WAF com Bot Control pago. Não há mTLS entre serviços porque não há chamada entre eles. Não há detecção de fraude em lançamento (valor atípico, horário): isso é regra de negócio futura, com falso positivo que o comerciante teria de confirmar. Registrar o limite do controle evita que a lista acima seja lida como certificação.